honorapp — Revisión de seguridad y datos personales

Oct 16, 2026 · @Grafica Dnews

Veredicto

El modelo de datos ya aprobado resuelve bien el aislamiento entre profesionales. Los problemas más serios están en otros tres lugares: el servidor en Brasil, el plan gratuito de Supabase y la configuración de autenticación por defecto.

- **Transferencia a Brasil.** Brasil no figura en la lista de países con protección adecuada de la Disposición 60/2016. Hay que resolverlo antes de cargar datos reales: cláusulas modelo, mover el proyecto a una región de la UE o consentimiento de cada paciente. Lo decide el abogado.
- **Plan gratuito no apto para datos reales.** Supabase hace backups diarios solo en planes pagos, y la detección de contraseñas filtradas, los límites de sesión y la inactividad requieren Pro. Con usuarios reales, Pro es obligatorio.
- **Cifrar nombres y montos por campo no conviene en v1.** La clave quedaría en el mismo servidor que descifra, así que no protege contra los riesgos reales (fallo de RLS, cuenta robada) y rompe sumas, búsquedas y la aplicación FIFO. Se explica en Cifrado.
- **No hay bloqueo por cuenta.** Supabase limita intentos por IP, no por usuario. Hace falta CAPTCHA, detección de contraseñas filtradas y MFA.
- **Agregados al modelo:** política restrictiva de MFA en todas las tablas, ningún archivo de importación guardado en el servidor y exports generados en el navegador.

Nada legal de este documento reemplaza la opinión de un abogado. Lo que no pude confirmar en fuentes oficiales está marcado.

Modelo multiusuario

Cada profesional es un usuario de Supabase Auth y cada fila de cada tabla lleva su `owner_id`; seis capas garantizan que nadie vea ni toque filas ajenas. El detalle completo de campos está en la especificación del modelo de datos v1.

Tablas y relaciones principales

Tabla	Campos clave	Relaciones
`profesionales`	`id` (= `auth.users.id`), `nombre`, `zona_horaria`	1:1 con `auth.users`
`pacientes`	`owner_id`, `nombre_visible` (alias o iniciales), `telefono?`, `email?`	N:1 profesional
`aranceles`, `agendas`	`owner_id`, `paciente_id`, montos o frecuencia, vigencia	N:1 paciente
`prestaciones`	`owner_id`, `paciente_id`, `fecha`, `estado`	N:1 paciente
`cargos`	`owner_id`, `prestacion_id?`, deudor, `monto`, `moneda`	N:1 prestación
`pagos`	`owner_id`, pagador, `monto`, `moneda`, `tc_*`	N:1 paciente
`imputaciones`	`owner_id`, `pago_id`, `cargo_id`, montos	N:M entre pagos y cargos
`auditoria`	`owner_id`, `tabla`, `registro_id`, `cambios`	Sin datos personales en `cambios`

Las seis capas de aislamiento

Capa	Qué evita
RLS en las 16 tablas: `owner_id = (select auth.uid())`	Leer o escribir filas de otro profesional desde el cliente
FK compuestas `(x_id, owner_id)`	Que una fila propia apunte a un paciente o pago ajeno (las FK ignoran RLS)
RPCs `security definer` con filtro explícito por `auth.uid()` y `search_path = ''`	Que las funciones que saltean RLS filtren datos de otros
Vistas con `security_invoker = true`	Que una vista muestre filas de todos los usuarios
Política `restrictive` de MFA	Que una sesión sin segundo factor lea datos de quien activó MFA
Sin Storage para importaciones	Archivos con nombres de pacientes guardados en un bucket mal configurado

Política de MFA (agregado al modelo)

Se suma en cada tabla, junto a la política por `owner_id`. Es el patrón documentado por Supabase: exige `aal2` solo a quien tiene un factor verificado.

```
create policy mfa_si_corresponde on pacientes
  as restrictive to authenticated
  using (
    array[(select auth.jwt()->>'aal')] <@ (
      select case when count(id) > 0 then array['aal2']
                  else array['aal1','aal2'] end
      from auth.mfa_factors
      where user_id = (select auth.uid()) and status = 'verified'));
```

Importación y export sin Storage

El archivo de Excel/CSV se lee en el navegador, se muestra la vista previa y se mandan solo las filas a la RPC de importación. El archivo original nunca sube al servidor. El export se arma también en el navegador y se descarga directo, sin quedar guardado en Supabase.

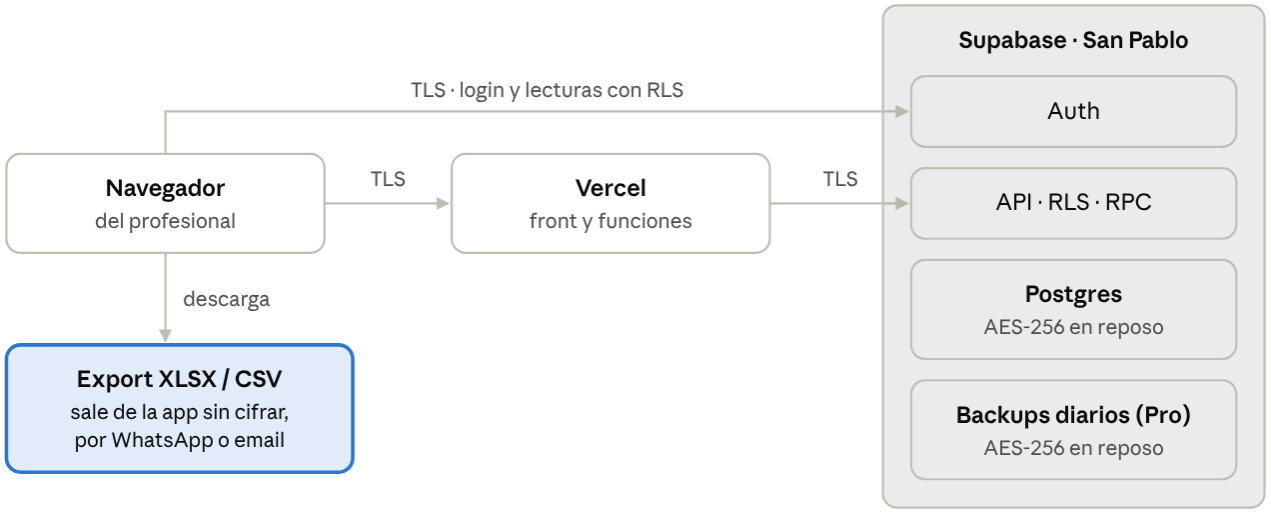
Cifrado

En tránsito y en reposo el cifrado ya lo dan Vercel y Supabase; lo que queda a cargo de honorapp es proteger las claves, los exports y los logs, que es por donde realmente se escapan los datos.

Dónde	Qué se cifra	Cómo	A cargo de	Acción en honorapp
Navegador ↔ Vercel	Todo el tráfico	HTTPS (TLS) automático	Vercel	Activar HSTS en los headers
Navegador ↔ Supabase	API, Auth, RPCs	TLS	Supabase	Usar solo la URL `https` del proyecto
Conexiones directas a Postgres	Migraciones, scripts	TLS	Supabase	Activar "Enforce SSL" en el proyecto
Base, Auth y backups en disco	Todos los datos	AES-256 en reposo	Supabase	Nada: viene activado

Dónde	Qué se cifra	Cómo	A cargo de	Acción en honorapp
Claves de Supabase	`service_role`, claves JWT	Variables de entorno del servidor	honorapp	Nunca en el cliente, nunca con prefijo `NEXT_PUBLIC_`, nunca en el repo
Exports (XLSX/CSV)	Nombres y montos	Se generan en el navegador	honorapp	No guardarlos en el servidor; opción de exportar con iniciales
Backups manuales (`pg_dump`)	La base completa	Cifrar el archivo (por ejemplo con `age` o GPG)	honorapp	Nunca guardarlos sin cifrar en Drive o en la PC
Logs de Vercel y errores	Lo que se loguee	No aplica: se evita loguear	honorapp	No loguear nombres, montos ni cuerpos de requests

Los datos viajan cifrados; el punto débil es el export



recorrido de los datos · dónde se cifran

Todo tramo entre sistemas va por TLS y todo lo guardado en Supabase está cifrado; el export, una vez descargado, queda fuera de esa protección.

Por qué no cifrar nombres y montos por campo en v1

- La clave tendría que estar en Vercel o en Supabase, que son los mismos que descifran para mostrar los datos. Un atacante que roba una sesión o explota un error de RLS recibe los datos ya descifrados.

- Lo único que agrega es protección ante un robo del disco o de un backup de Supabase, que ya están cifrados con AES-256.
- Rompe las sumas, los saldos, la aplicación FIFO y las búsquedas, porque Postgres no puede operar sobre valores cifrados.

Opción a futuro: cifrado de extremo a extremo

Si en algún momento hace falta que ni siquiera honorapp pueda leer los nombres (argumento de secreto profesional para psicólogos), la alternativa real es cifrar `nombre_visible`, `telefono` y `email` en el navegador con una clave derivada de una frase que solo conoce el profesional. Los montos quedarían en claro para poder calcular. Costo: si el profesional olvida la frase, pierde los nombres sin recuperación posible. No es para v1.

Autenticación

La configuración por defecto de Supabase Auth no alcanza para datos sensibles: hay que subir el largo mínimo, activar CAPTCHA, configurar un SMTP propio y pasar a Pro para cortar sesiones por inactividad.

Tema	Configuración recomendada	Requiere Pro
Largo de contraseña	Mínimo 12 caracteres. Supabase desaconseja menos de 8; 12 es mi recomendación. Sin reglas de composición obligatorias, para permitir frases largas	No
Contraseñas filtradas	Activar la verificación contra HaveIBeenPwned	**Sí**
Cambio de contraseña	Exigir la contraseña actual y reautenticación si la sesión tiene más de 24 h	No
Verificación de email	Confirmación obligatoria antes del primer acceso	No
Envío de emails	SMTP propio (el integrado permite solo 2 emails por hora) con SPF, DKIM y DMARC en el dominio	No
Límite de intentos	Los límites por IP de Supabase (30 inicios de sesión cada 5 minutos) + CAPTCHA Turnstile en registro, inicio de sesión y recupero	No
Bloqueo por cuenta	No existe de forma nativa: un ataque distribuido desde muchas IPs no se frena por IP. Lo cubren CAPTCHA, contraseñas filtradas y MFA. *Un bloqueo propio por hook de Auth es posible, a verificar en qué plan*	A verificar

Tema	Configuración recomendada	Requiere Pro
Token de acceso	1 hora (valor por defecto, el recomendado)	No
Refresh token	Rotación y detección de reutilización activadas (vienen así; no desactivar)	No
Inactividad	Cerrar sesión tras 12 h sin uso: pensado para PC compartidas de consultorio	**Sí**
Duración máxima	Reautenticación obligatoria cada 14 días	**Sí**
Cerrar sesiones	Botón "Cerrar sesión en todos los dispositivos"	No
MFA	TOTP opcional, ofrecido al registrarse, con la política restrictiva de RLS. *Verificar si Supabase ofrece códigos de recuperación; si no, permitir registrar dos dispositivos*	No
Mensajes de error	Iguales para usuario inexistente y contraseña incorrecta, para no revelar quién tiene cuenta	No

Sesión en Next.js

Con `@supabase/ssr` la sesión vive en cookies que el JavaScript de la página puede leer. *A verificar en la versión que uses.* Si es así, un XSS podría robar la sesión, por eso la Content Security Policy pasa a ser obligatoria (ver Riesgos).

Ley 25.326 de Protección de Datos Personales

La Ley 25.326 sigue vigente al 16/10/2026; hay proyectos de reforma en el Congreso, pero no encontré ninguno aprobado. Lo que sigue es lectura de la ley y de normas de la AAIP, no asesoramiento legal: cada punto lo valida el abogado.

Roles: quién es responsable de qué

- **El profesional** es responsable de la base de sus pacientes. La ley habilita a los profesionales de la salud a tratar datos de salud de sus pacientes respetando el secreto profesional (art. 8).
- **honorapp** actúa como prestador de servicios de tratamiento para esos datos (art. 25): no puede usarlos para otra finalidad, ni cederlos, ni conservarlos al terminar el servicio. Al terminar, se destruyen, salvo autorización expresa del profesional para conservarlos hasta 2 años.
- **honorapp es responsable** de los datos de sus propios usuarios (los profesionales).

- Consecuencia práctica: los términos y condiciones tienen que funcionar como contrato de prestación de servicios de tratamiento, no solo como política de privacidad.

Datos sensibles

La ley define como sensibles los datos que revelan información de salud (art. 2). Un nombre asociado a pagos a una psicóloga puede revelar que esa persona hace terapia. Diseño asumiendo que son sensibles: es la lectura prudente. *Si efectivamente lo son, y cómo se combina el art. 7 con el art. 8 en una base de varios profesionales, lo define el abogado.*

Consentimiento

Titular	Base que parece aplicar	Qué hace honorapp
Paciente	Excepción por relación profesional: datos necesarios para esa relación (art. 5, inc. 2) y habilitación del art. 8	Igual existe el deber de informar (art. 6). Darle al profesional un modelo de aviso para sus pacientes y la tabla `consentimientos` lista por si el abogado lo exige
Profesional (usuario)	Consentimiento libre, expreso e informado (art. 5)	Casilla al registrarse, política de privacidad, versión aceptada y fecha guardadas

El aviso del art. 6 tiene que decir: finalidad, destinatarios, quién es el responsable y su domicilio, si dar los datos es obligatorio y los derechos de acceso, rectificación y supresión.

Registro de bases de datos

- El art. 21 exige inscribir las bases públicas y las privadas destinadas a dar informes. La AAIP, desde la Disposición 2/2005, viene exigiendo la inscripción de responsables del sector privado en general. *Hay discusión sobre el alcance.*
- El trámite es por Trámites a Distancia (TAD), gratuito y sin vencimiento según la página oficial. Primero se inscribe el responsable y después cada base.
- **Recomendación:** inscribir honorapp como responsable de su base de usuarios. Es gratis y reduce riesgo. *Si cada profesional tiene que inscribir su base de pacientes, lo define el abogado.*
- *La página oficial pide estatuto o contrato social: verificar el formulario si honorapp está a tu nombre como persona humana.*

Derechos de los pacientes y de los profesionales

Derecho	Plazo legal	Cómo se resuelve en honorapp
Acceso	10 días corridos desde el pedido; gratuito cada 6 meses (art. 14)	Botón "Exportar datos de este paciente" para que el profesional responda. Para los profesionales, "Descargar todos mis datos"
Rectificación	5 días hábiles (art. 16)	Edición normal desde la app
Supresión	5 días hábiles (art. 16)	`suprimir_paciente` (anonimización). La ley exceptúa la supresión cuando hay obligación legal de conservar, lo que respalda conservar los registros contables anonimizados
Supresión de la cuenta del profesional	Art. 25: destruir al terminar el servicio	Borrado completo de la cuenta y todos sus datos, con 30 días de gracia para descargar

Canal: un email visible en la app para pedidos. El profesional responde por sus pacientes; honorapp, por sus usuarios.

Seguridad y confidencialidad

- El art. 9 exige medidas técnicas y organizativas, y prohíbe guardar datos en sistemas sin condiciones de seguridad. La Resolución AAIP 47/2018 tiene las medidas recomendadas. *No la revisé en detalle; hay que contrastar la checklist con ella.*
- El art. 10 te obliga al secreto profesional como desarrollador, incluso después de terminar el servicio. En la práctica: no navegar datos de producción, acceso a producción solo con MFA y que quede documentado.

Transferencia internacional: el punto más serio

- El art. 12 prohíbe transferir datos a países sin protección adecuada. **Brasil no está en la lista de la Disposición 60/2016.** Están la UE y el Espacio Económico Europeo, Suiza, Uruguay, Nueva Zelanda, Andorra, Israel (con limitaciones), Canadá (sector privado), las islas Faroe, Guernsey, Jersey y la Isla de Man.
- **Opciones:**
  1. **Cláusulas contractuales modelo** con el proveedor (Disposición 60/2016, anexo de prestación de servicios, o Resolución AAIP 198/2023). Un contrato que se aparte del modelo requiere aprobación de la AAIP dentro de los 30 días. Problema: Supabase difícilmente firme cláusulas argentinas a medida.

2. **Mover el proyecto a una región de la UE** (país adecuado). Problema: más latencia desde Argentina, y Supabase y Vercel son empresas de EE.UU. con subprocesadores propios.
3. **Consentimiento expreso de cada paciente para la transferencia.** Problema: poco práctico y depende de cada profesional.

- La excepción del art. 12 para datos médicos se refiere a datos necesarios para el tratamiento del paciente. No parece cubrir datos de cobros. *A confirmar.*
- Si se mueve la base, las funciones de Vercel deberían correr en la misma región.

Incidentes de seguridad

La Ley 25.326 no obliga a notificar incidentes. El Convenio 108+ (ratificado por Ley 27.699) prevé avisar a la AAIP dentro de 72 horas en incidentes graves, pero según una guía de 2025 todavía no entró en vigor. *Verificar si cambió en 2026.* Recomiendo tener un plan de respuesta igual.

Reforma en curso

Hay proyectos de reforma presentados en 2025 y 2026, entre ellos el expediente 2580-D-2026 (junio de 2026), sin aprobación según lo encontrado. Siguen el modelo europeo. El diseño ya va en esa dirección (minimización, supresión, auditoría, plan de incidentes), así que una reforma no debería obligar a rehacerlo.

Los 5 riesgos más probables

Ordenados por probabilidad para una app hecha por una sola persona sobre Supabase. El primero es, por lejos, el más probable y el más grave.

#	Riesgo	Cómo pasa	Mitigación
1	**Un profesional ve datos de otro**	Una tabla nueva sin RLS, una vista sin `security_invoker`, una RPC `security definer` sin filtro por `auth.uid()`, una FK que apunta a una fila ajena	Tests automáticos de aislamiento con dos usuarios en cada cambio de esquema (próximo paso). Revisar el Security Advisor de Supabase antes de cada deploy. Ninguna migración a producción sin pasar los tests
2	**Robo de la cuenta de un profesional**	Contraseña reutilizada y filtrada en otro sitio, phishing, sesión abierta en la PC compartida del consultorio	Detección de contraseñas filtradas, CAPTCHA, MFA ofrecido en el registro, cierre por inactividad, botón para cerrar todas las sesiones

#	Riesgo	Cómo pasa	Mitigación
3	**Filtración de claves o mala configuración**	La clave `service_role` en el cliente o en GitHub, un deploy de preview conectado a la base de producción, logs con datos de pacientes	Repo privado con secret scanning; proyectos de Supabase separados para desarrollo y producción; previews apuntando a desarrollo; rotar la clave si alguna vez se expuso; no loguear datos
4	**Fugas por exports e importaciones**	El XLSX viaja por WhatsApp o email al contador; un nombre de paciente como `=HYPERLINK(...)` ejecuta una fórmula al abrir el export en Excel; un nombre con HTML intenta un XSS	Opción de exportar con iniciales; escapar celdas que empiezan con `=`, `+`, `-` o `@`; no usar `dangerouslySetInnerHTML`; Content Security Policy estricta; registrar cada export en la auditoría
5	**Pérdida de datos**	Plan gratuito sin backups diarios, una migración que borra una columna, una anulación masiva por error	Plan Pro con backups diarios; evaluar el agregado de recuperación a un punto en el tiempo; probar restaurar un backup antes del lanzamiento; migraciones revisadas y versionadas en el repo

Checklist antes de cargar datos reales

Todo tiene que estar tildado antes de que el primer profesional cargue un paciente real; los ítems legales dependen de la respuesta del abogado.

Base de datos

- [ ] RLS activado en las 16 tablas, verificado con una consulta al catálogo
- [ ] Tests de aislamiento entre dos usuarios pasando, incluidos RPCs, vistas y FK compuestas
- [ ] Todas las vistas con `security_invoker = true`
- [ ] Todas las RPCs `security definer` con `search_path = ''` y filtro por `auth.uid()`
- [ ] `execute` revocado a `anon` en todas las funciones
- [ ] Política restrictiva de MFA en todas las tablas

- [ ] Security Advisor de Supabase sin alertas críticas
- [ ] Ningún bucket de Storage con datos de pacientes

Autenticación

- [ ] Contraseña mínima de 12 caracteres y detección de contraseñas filtradas activada
- [ ] Confirmación de email obligatoria
- [ ] SMTP propio con SPF, DKIM y DMARC configurados
- [ ] CAPTCHA en registro, inicio de sesión y recupero de contraseña
- [ ] Cierre por inactividad y duración máxima de sesión configurados
- [ ] Cambio de contraseña con reautenticación
- [ ] MFA probado de punta a punta, incluido qué pasa si se pierde el dispositivo

Infraestructura y claves

- [ ] Supabase en plan Pro, con backups diarios verificados
- [ ] Restauración de un backup probada al menos una vez
- [ ] Proyectos separados de desarrollo y producción; deploys de preview apuntando a desarrollo
- [ ] Clave `service_role` fuera del cliente y del repo; repo privado con secret scanning
- [ ] "Enforce SSL" activado en la base
- [ ] Headers de seguridad en Vercel: HSTS, Content Security Policy, `X-Frame-Options`, `Referrer-Policy`
- [ ] Acceso al panel de Supabase, Vercel y GitHub con MFA
- [ ] Región de la base definida según la decisión legal sobre la transferencia

Aplicación

- [ ] Logs y reportes de errores sin nombres ni montos
- [ ] Export con escape de fórmulas y opción de iniciales
- [ ] Importación procesada en el navegador, sin subir el archivo original
- [ ] Ningún uso de `dangerouslySetInnerHTML` con datos de usuarios
- [ ] Dependencias auditadas y actualizadas

Datos personales y legal

- [ ] Decisión del abogado sobre la transferencia a Brasil implementada
- [ ] Términos y condiciones con contrato de prestación de servicios de tratamiento (art. 25)
- [ ] Política de privacidad publicada y aceptación registrada con versión y fecha
- [ ] Modelo de aviso a pacientes (art. 6) disponible para los profesionales

- [ ] Inscripción en el Registro Nacional de Bases de Datos hecha o descartada por escrito
- [ ] Exportar datos de un paciente, suprimir un paciente y borrar una cuenta funcionando
- [ ] Email de contacto para pedidos de acceso y supresión visible en la app
- [ ] Plan de respuesta a incidentes escrito: quién avisa, a quién y en qué plazo
- [ ] Checklist contrastada con la Resolución AAIP 47/2018

Fuentes

Consultadas el 16/10/2026.

Normativa

- Ley 25.326 de Protección de Datos Personales — texto en argentina.gob.ar
- Disposición 60-E/2016 — países adecuados y contratos modelo
- Resolución AAIP 198/2023 — cláusulas contractuales modelo (Boletín Oficial)
- Inscribir un responsable de bases de datos personales privadas — argentina.gob.ar
- Disposición 2/2005, Registro Nacional de Bases de Datos — Diario Judicial (2005)
- Guía de protección de datos de Argentina, 2025 — Multilaw / Zang, Bergel & Viñes
- Proyecto de reforma de la ley de datos personales en Diputados — Sexta (junio de 2026)
- Novedades legislativas sobre datos personales — IAPP (junio de 2025)

Supabase

- Seguridad en Supabase
- Password security
- User sessions
- Rate limits
- Multi-factor authentication
- CAPTCHA protection